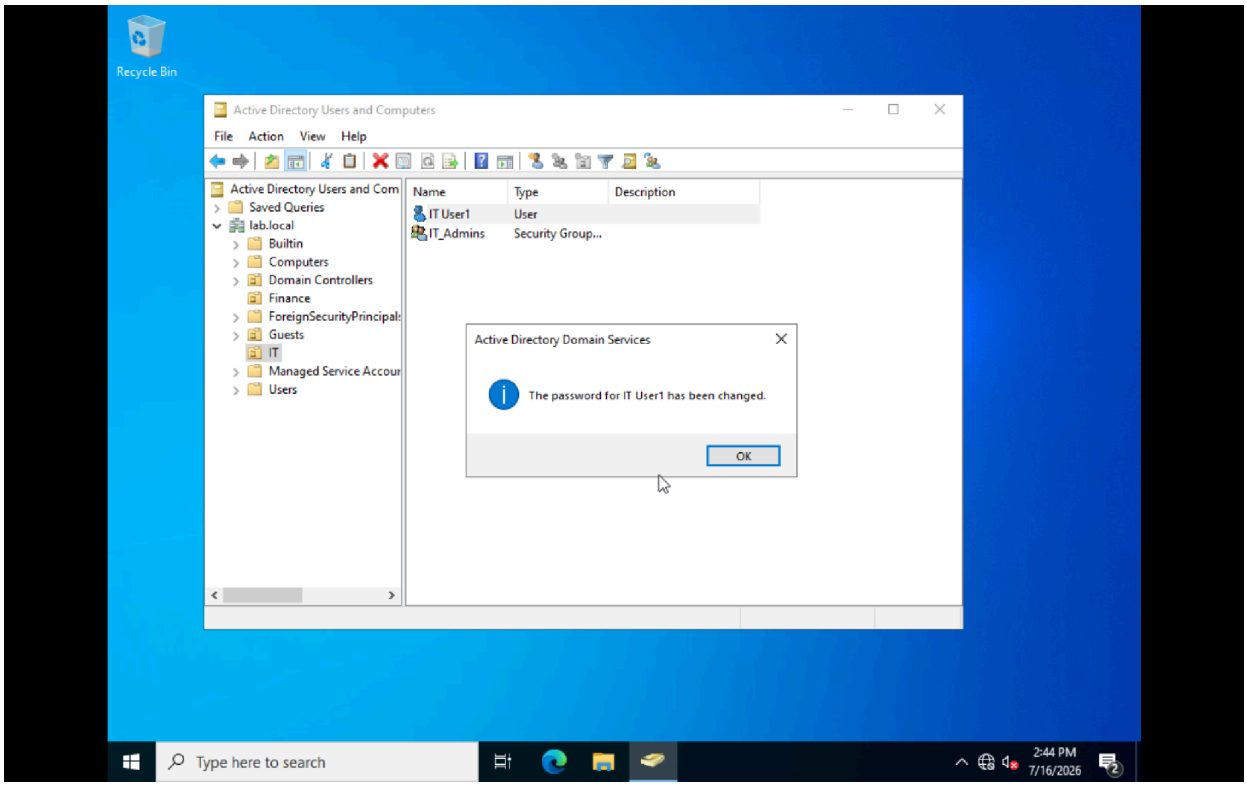
Active Directory Security Hardening Lab

A self-hosted Active Directory environment built to test least-privilege delegation, password policy hardening, and security auditing hands-on rather than just on paper. Below is each configuration step alongside the screenshot proving it worked.

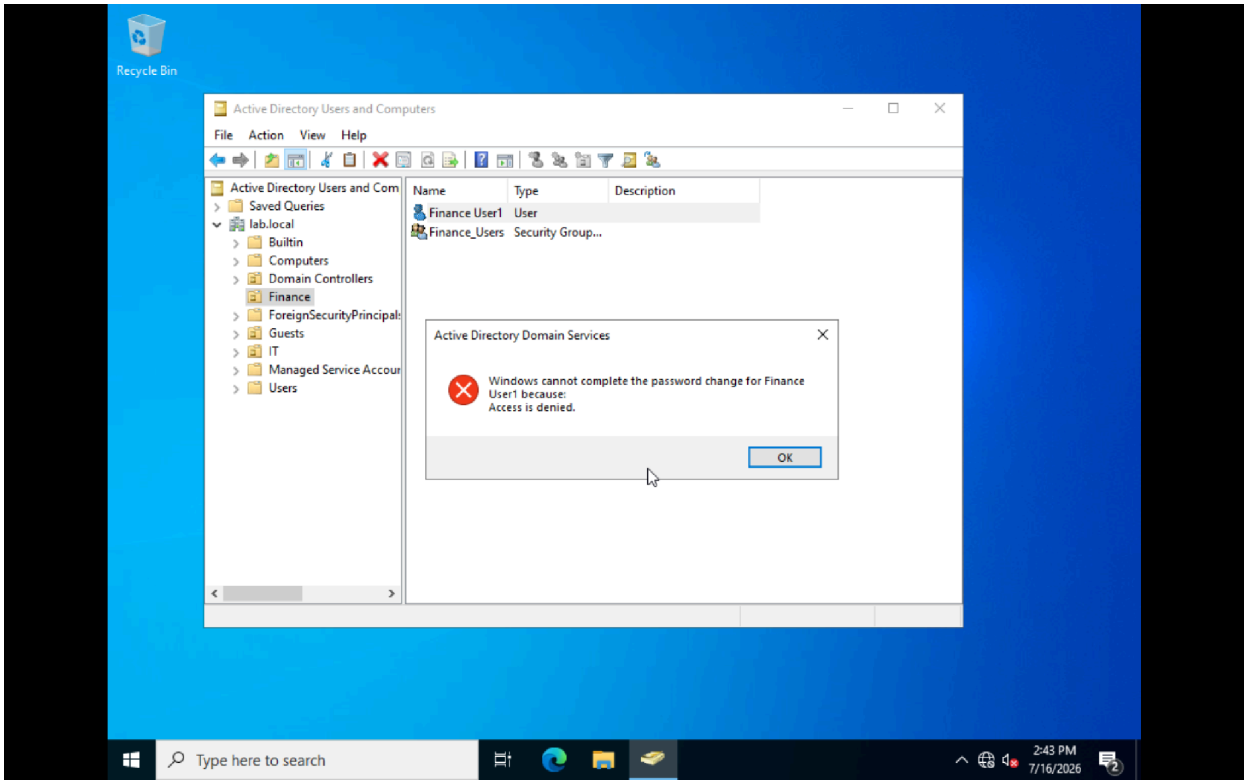
Part 1: Delegation and Least Privilege

I delegated control of the IT Organizational Unit to the IT_Admins security group, granting them rights to reset passwords and manage user accounts, but scoped only to that OU. The two screenshots below test that boundary directly.



Screenshot 1: Password reset succeeds inside the IT OU

Logged in as it_user1, a limited domain account, I reset the password for a user inside the IT OU. Since delegation grants this account rights within IT specifically, the action completes successfully, confirming the delegated permissions are live and working.

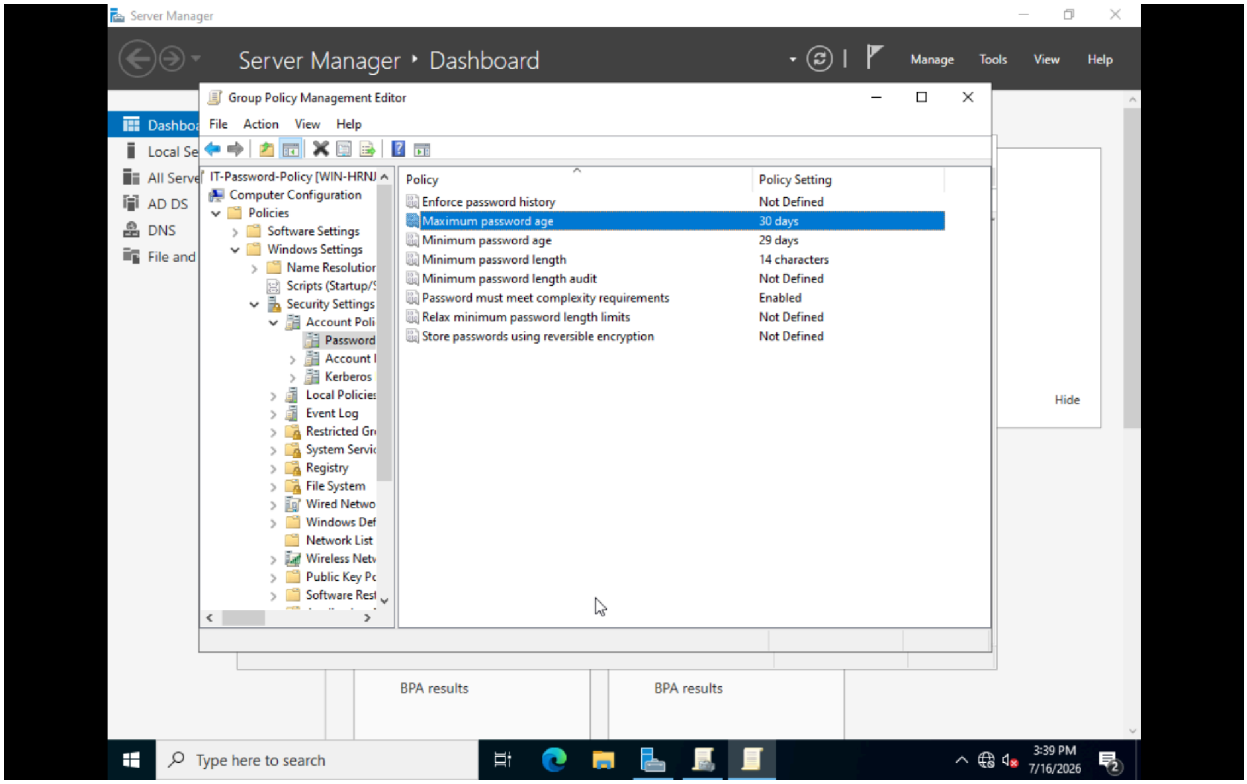


Screenshot 2: The same account is denied in the Finance OU

Using the exact same it_user1 account and the same tool, I attempted to reset a password for a user in the Finance OU instead. Windows returned Access is denied. This is the proof point of the whole exercise: delegation in Active Directory does not inherit sideways, so a compromised or over-curious IT account cannot touch Finance's accounts.

Part 2: Password Policy Hardening

Rather than relying on the domain's default password policy, I created a Group Policy Object scoped specifically to the IT OU with stricter requirements.

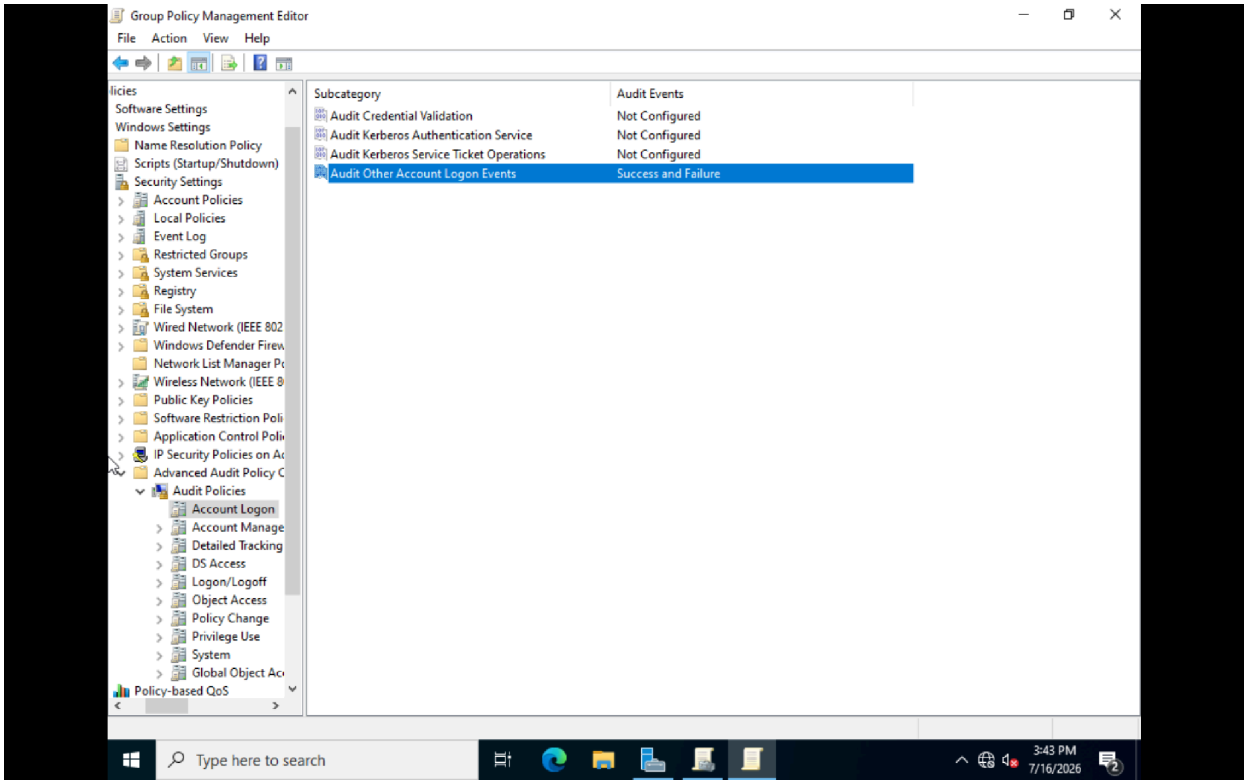


Screenshot 3: IT-Password-Policy GPO settings

This GPO, linked directly to the IT OU, raises the minimum password length to 14 characters, enables complexity requirements, and caps the maximum password age at 30 days. This is meaningfully stricter than Windows Server's out-of-the-box defaults and reflects a tiered approach where higher-privilege accounts get tighter controls.

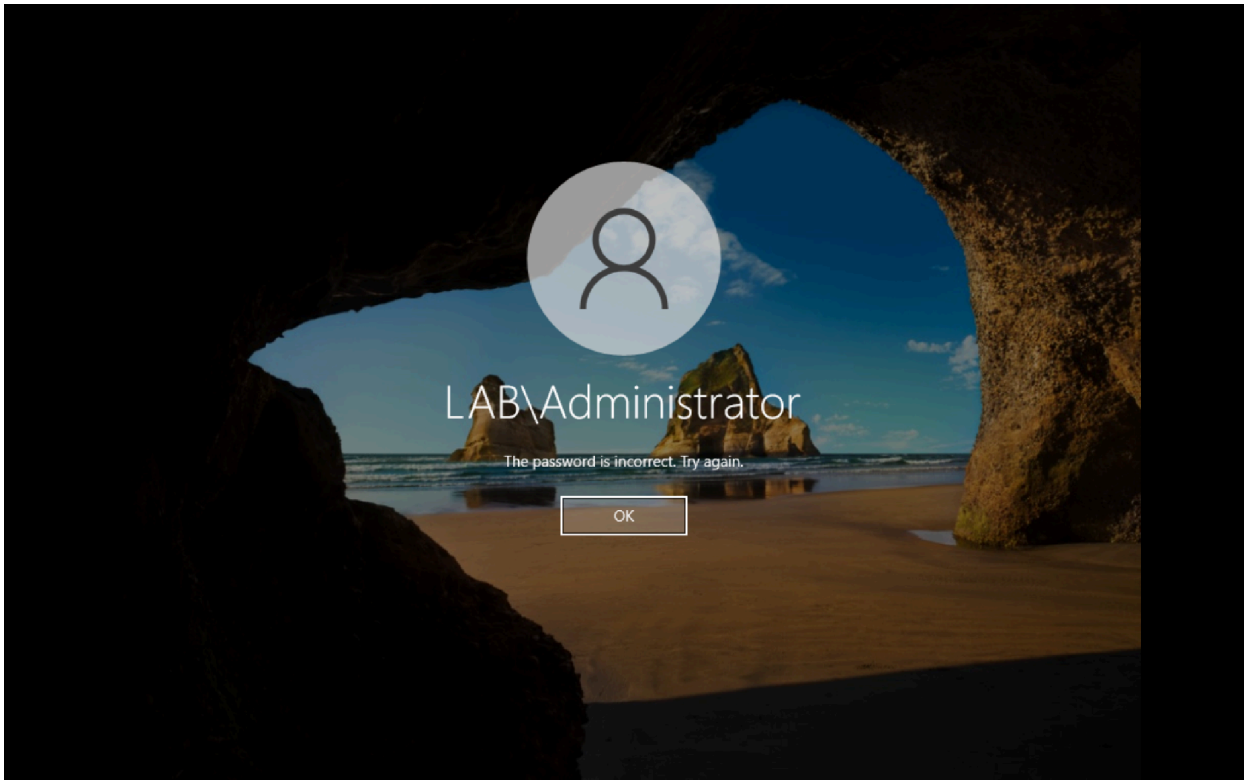
Part 3: Security Auditing

A security control that isn't logged is hard to verify or investigate after the fact. I enabled auditing for logon events, then deliberately triggered both a failed and successful login to confirm the audit trail was actually capturing activity.



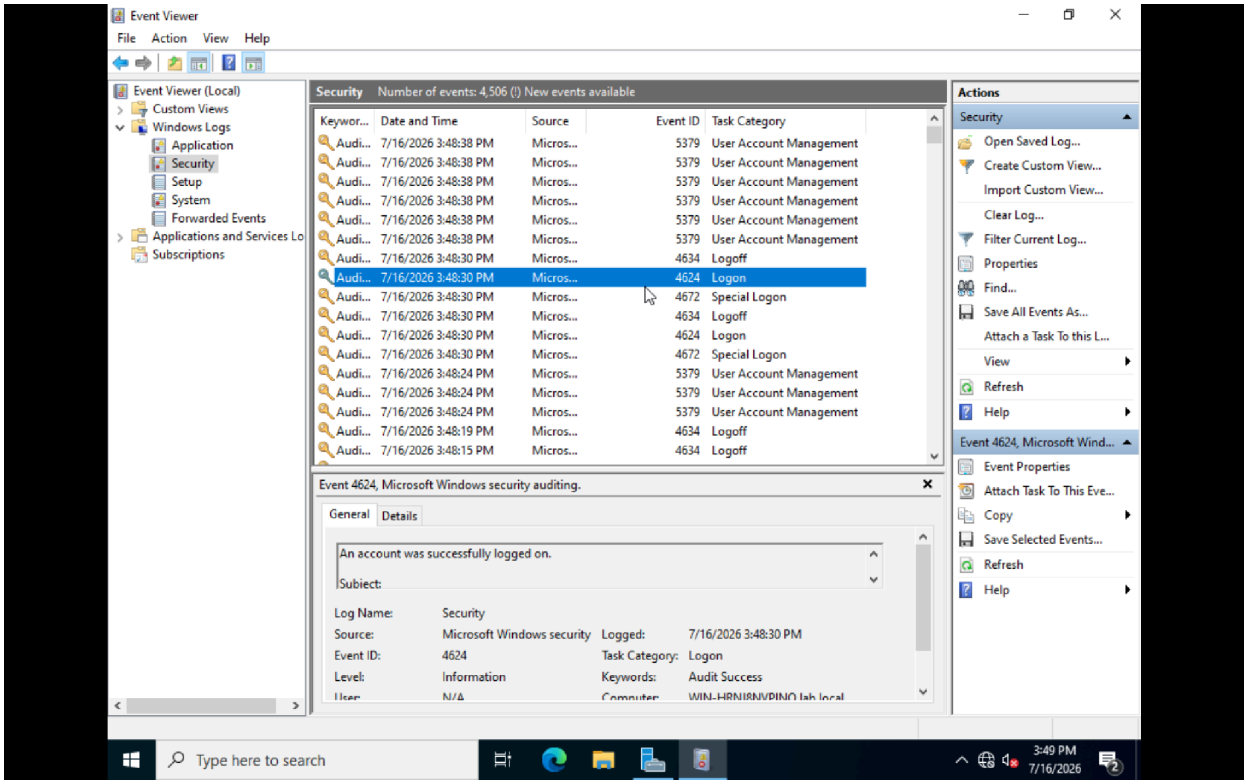
Screenshot 4: Advanced Audit Policy Configuration

Under Account Logon, I enabled auditing for Success and Failure events. This is a more granular setting than the legacy Audit Policy node, and it's what actually determines whether logon attempts get written to the Security event log.



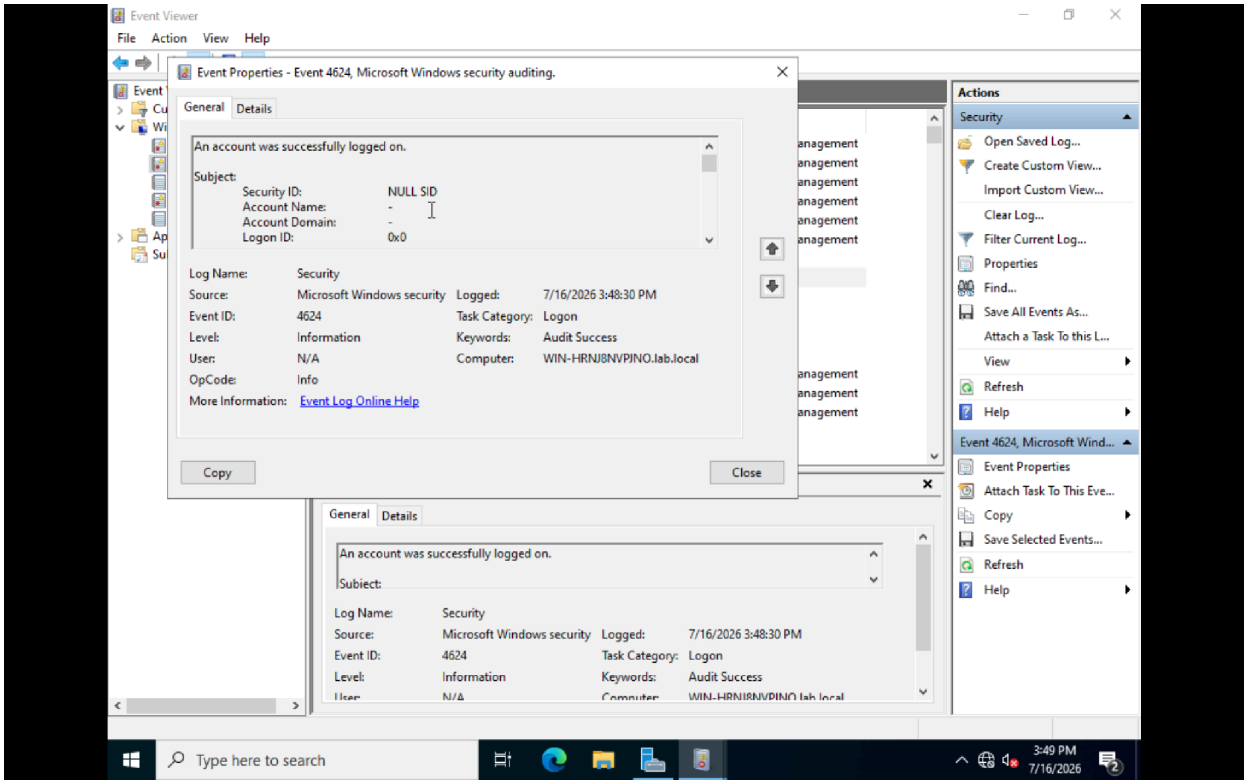
Screenshot 5: A deliberately incorrect password

To generate a test event, I intentionally typed the wrong password for the Administrator account. This is the kind of everyday failed-login activity the audit policy above should now be capturing.



Screenshot 6: Event Viewer showing captured activity

Opening the Security log in Event Viewer confirms the audit policy is working. Over 4,500 events are already logged, including Event ID 4624 (successful logon) and 4634 (logoff) entries generated during testing.

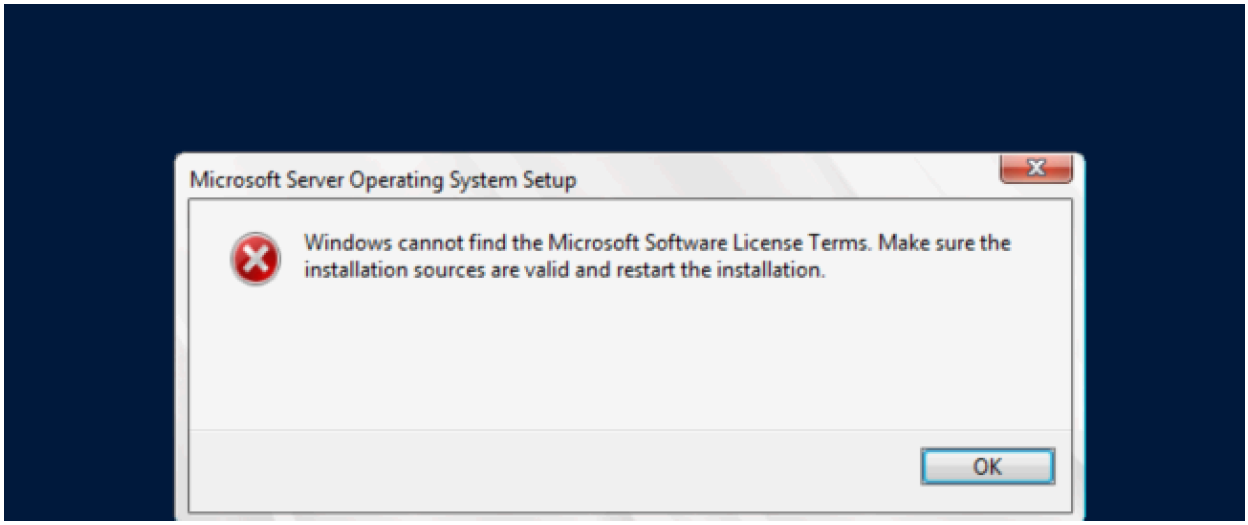


Screenshot 7: Event 4624 detail view

Drilling into a specific logon event shows the full metadata: timestamp, the computer it originated from, and the audit keyword confirming a successful logon. This is the level of detail that would matter during an actual investigation or audit review.

Troubleshooting Along the Way

Not everything went smoothly, and honestly, the troubleshooting taught me as much as the configuration steps did.



Screenshot 8: A recurring installer error

I hit this "Windows cannot find the Microsoft Software License Terms" error multiple times during the Windows Server install. It turned out to be caused by VMware Fusion's Easy Install feature silently injecting a broken unattended-install configuration file. Switching the VM's firmware to UEFI Secure Boot and manually stepping through the installer instead of using Easy Install resolved it for good.

Why This Matters

These are small-scale versions of controls that meaningfully limit blast radius in real environments. A compromised helpdesk account should never be able to touch Finance's data. Weak passwords shouldn't be tolerated by default. And when something does go wrong, there needs to be a log trail to investigate. Building this lab from scratch, and deliberately trying to break it, made these principles click in a way reading about them never did.